

Anlage B – Vertrag zur Auftragsverarbeitung (AVV) gemäß Art. 28 DSGVO

Stand: September 2026

Dieser Vertrag zur Auftragsverarbeitung (nachfolgend "AVV") ist Anlage B zum Rahmenvertrag zwischen den nachstehenden Parteien und konkretisiert die datenschutzrechtlichen Pflichten bei der Verarbeitung personenbezogener Daten im Auftrag.

Parteien

Auftragsverarbeiter: NexAI – Next Generation Artificial Intelligence GbR, Untere Bergstraße 13, 74586 Frankenhardt-Honhardt, Deutschland, vertreten durch die Gesellschafter Maximilian Trenk und Jason Brian Merklein, E-Mail mbt@nex-a-i.com, Telefon 0176 80714816 — nachfolgend "NexAI".

Verantwortlicher (Kunde):

Firma / Rechtsform: _____

Anschrift: _____

Vertreten durch: _____

E-Mail: _____

Telefon: _____

— nachfolgend "Kunde". NexAI und der Kunde nachfolgend gemeinsam "Parteien", einzeln "Partei".

§ 1 Präambel, Gegenstand und Rollenverteilung

- (1) NexAI erbringt für den Kunden Leistungen im Zusammenhang mit der Bereitstellung und dem Betrieb KI-gestützter Agenten (Voice Agent, Chat Agent, Automatisierungen, individuelle KI-Agenten – nachfolgend "Agenten") sowie von Softwareanwendungen (NexAI CRM, NexAI Kalender, individuelle Anwendungen – nachfolgend "Anwendungen") und zugehöriger Projekt- und Betriebsleistungen. Im Rahmen dieser Leistungen verarbeitet NexAI personenbezogene Daten im Auftrag des Kunden.
- (2) Der Kunde ist hinsichtlich der im Auftrag verarbeiteten personenbezogenen Daten **Verantwortlicher** im Sinne des Art. 4 Nr. 7 DSGVO. NexAI ist insoweit **Auftragsverarbeiter** im Sinne des Art. 4 Nr. 8 DSGVO und verarbeitet die Daten ausschließlich weisungsgebunden nach Maßgabe dieses AVV.
- (3) Gegenstand dieses AVV ist die Konkretisierung der datenschutzrechtlichen Rechte und Pflichten der Parteien nach Art. 28 DSGVO. Die Zuordnung der Rolle von NexAI je Leistungsart ergibt sich aus der Rollenmatrix in § 15.
- (4) Bei Widersprüchen zwischen diesem AVV und den übrigen Vertragsdokumenten (Rahmenvertrag, Auftragsformular/Leistungsschein, Anlage A, Anlage C, Anlage D, AGB) gehen in **datenschutzrechtlichen Fragen** die Regelungen dieses AVV vor (Sachvorrang). Im Übrigen gelten die Regelungen des Rahmenvertrags und seiner Anlagen fort.
- (5) Die eigene straf-, ordnungswidrigkeiten- und bußgeldrechtliche Verantwortlichkeit von NexAI sowie eine etwaige eigene datenschutzrechtliche Verantwortlichkeit von NexAI für Zwecke, die NexAI selbst bestimmt, bleiben von diesem AVV unberührt.

§ 2 Art, Umfang, Zweck und Dauer der Verarbeitung

- (1) **Art der Verarbeitung:** Erheben, Erfassen, Organisieren, Speichern, Anpassen, Auslesen, Abfragen, Verwenden, Übermitteln, Bereitstellen, Kombinieren, Einschränken und Löschen personenbezogener Daten mittels automatisierter Verfahren im Rahmen des Betriebs der Agenten und Anwendungen (u. a. Sprachdialog, Chatdialog, Terminvereinbarung und Terminverwaltung, Weiterleitung, Automatisierungen, Verwaltung von Kontakt-, Vorgangs- und Aufgabendaten, Versand von Bestätigungen und Erinnerungen).
- (2) **Zweck der Verarbeitung:** Bereitstellung, Einrichtung, Betrieb, Wartung und Support der Agenten und Anwendungen für den Kunden, insbesondere die Beantwortung von Anfragen von Endnutzern, die Vereinbarung, Verwaltung und Bestätigung von Terminen, die Weiterleitung von Anliegen sowie die Verwaltung der Kontakt-, Vorgangs- und Aufgabendaten des Kunden in den beauftragten Anwendungen.
- (3) **Umfang der Verarbeitung:** bestimmt sich nach den im Auftragsformular/Leistungsschein und in Anlage A (Leistungsbeschreibung) festgelegten Agenten, Anwendungen und Funktionen sowie nach den dokumentierten Weisungen des Kunden.
- (4) **Dauer der Verarbeitung:** Die Verarbeitung beginnt mit der Aufnahme der Leistungserbringung und endet mit Beendigung des Rahmenvertrags bzw. der jeweiligen Leistung, vorbehaltlich der Regelungen zu Löschung und Rückgabe (§ 12) und etwaiger gesetzlicher Aufbewahrungspflichten. Dieser AVV gilt für die Dauer der Verarbeitung personenbezogener Daten im Auftrag.

§ 3 Kategorien betroffener Personen und personenbezogener Daten

Gegenstand der Verarbeitung sind – abhängig von den beauftragten Agenten und Anwendungen – die folgenden Kategorien:

3.1 Kategorien betroffener Personen

- Ansprechpartner, Beschäftigte und Vertreter des Kunden (Nutzer der Verwaltungs-/Konfigurationsfunktionen, Kontaktpersonen);
- **Endnutzer** – Personen, die mit den Agenten oder Anwendungen interagieren, insbesondere Anrufer (Voice Agent), Chat-Kontakte (Chat Agent), Personen, die einen Termin buchen (NexAI Kalender), sowie Nutzerinnen und Nutzer einer für den Kunden betriebenen Anwendung (NexAI App);
- Kontakte, Interessenten und Kundschaft des Kunden, deren Daten der Kunde in den beauftragten Anwendungen speichert oder die aus den Agenten dorthin übernommen werden (NexAI CRM, NexAI Kalender);
- Dritte, deren Daten von Endnutzern im Verlauf einer Interaktion oder in einem Freitextfeld mitgeteilt werden (z. B. genannte Kontaktpersonen).

3.2 Kategorien personenbezogener Daten

- Kontakt- und Stammdaten (Name, Anrede, Firma/Funktion, Telefonnummer, E-Mail-Adresse, Anschrift);
- Gesprächs- und Kommunikationsinhalte (Inhalte von Anrufen, Chats, Nachrichten);
- Transkripte und – nur bei ausdrücklich aktivierter Funktion – Aufzeichnungen von Gesprächen;
- Termindaten (Terminwünsche, Datum/Uhrzeit, Anlass, Status);
- Anliegen-, Vorgangs- und Statusdaten (Anfrage, Kategorie, Ergebnis, Weiterleitung);

- Auftrags-, Vorgangs- und Belegdaten, soweit der Kunde solche in einer Anwendung führt (z. B. Leistung, Betrag, Status);
- Notizen und Freitexte, die der Kunde oder Endnutzer in einer Anwendung erfassen;
- Zugangs- und Protokolldaten der Nutzerkonten des Kunden (Anmeldedaten – Passwörter ausschließlich als Prüfsumme –, Sitzungen, Änderungsprotokoll);
- Metadaten und technische Daten (Verbindungs-/Nutzungsdaten, Zeitstempel, Kennungen, Kanal, Dauer, technische Protokolldaten).

Besondere Kategorien personenbezogener Daten (Art. 9 DSGVO) sind nicht Gegenstand der beauftragten Verarbeitung. Der Kunde stellt durch geeignete Konfiguration und Weisung sicher, dass die Agenten nicht gezielt zur Erhebung solcher Daten eingesetzt werden. Werden derartige Daten durch Endnutzer unaufgefordert mitgeteilt, verarbeitet NexAI sie ausschließlich im Rahmen der dokumentierten Weisungen und der Löschroutinen dieses AVV.

§ 4 Weisungsbindung

- (1) NexAI verarbeitet personenbezogene Daten ausschließlich auf **dokumentierte Weisung** des Kunden, es sei denn, NexAI ist nach Unionsrecht oder dem Recht eines Mitgliedstaats zur Verarbeitung verpflichtet (Art. 28 Abs. 3 lit. a DSGVO). In diesem Fall teilt NexAI dem Kunden diese rechtliche Anforderung vor der Verarbeitung mit, sofern das betreffende Recht eine solche Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet.
- (2) Die maßgeblichen Weisungen sind in diesem AVV und den übrigen Vertragsdokumenten festgelegt (Erstweisung). Weitergehende Einzelweisungen erteilt der Kunde in Textform gegenüber der in § 14 genannten Kontaktstelle. Mündliche Weisungen bestätigt der Kunde unverzüglich in Textform.
- (3) NexAI informiert den Kunden unverzüglich, wenn NexAI der Auffassung ist, dass eine Weisung gegen datenschutzrechtliche Vorschriften verstößt (Art. 28 Abs. 3 Satz 3 DSGVO). NexAI ist berechtigt, die Durchführung der betreffenden Weisung bis zu deren Bestätigung oder Änderung durch den Kunden auszusetzen.
- (4) Der Kunde trägt die Verantwortung für die Rechtmäßigkeit der Weisungen und der Verarbeitung, insbesondere für das Vorliegen einer tragfähigen Rechtsgrundlage.

§ 5 Vertraulichkeit

- (1) NexAI verpflichtet die mit der Verarbeitung befassten Personen zur Vertraulichkeit, soweit sie nicht bereits einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen (Art. 28 Abs. 3 lit. b, Art. 29, Art. 32 Abs. 4 DSGVO).
- (2) NexAI stellt sicher, dass Personen, die zur Verarbeitung der personenbezogenen Daten befugt sind, mit den einschlägigen datenschutzrechtlichen Anforderungen vertraut sind und Daten nur auf Weisung verarbeiten. Die Verpflichtung besteht auch nach Beendigung der Tätigkeit fort.
- (3) Als Gesellschafter der NexAI GbR sind Maximilian Trenk und Jason Brian Merklein unmittelbar zur Vertraulichkeit verpflichtet.

§ 6 Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

- (1) NexAI trifft die zur Gewährleistung eines dem Risiko angemessenen Schutzniveaus erforderlichen technischen und organisatorischen Maßnahmen nach Art. 32 DSGVO. Die zum Zeitpunkt des Vertragsschlusses getroffenen Maßnahmen sind in **Anhang 1 (Technische und organisatorische Maßnahmen)** beschrieben und sind Bestandteil dieses AVV.

- (2) NexAI ist berechtigt, die Maßnahmen an den Stand der Technik und an geänderte tatsächliche Verhältnisse anzupassen, sofern das vereinbarte Schutzniveau nicht unterschritten wird. Wesentliche Änderungen dokumentiert NexAI und stellt sie dem Kunden auf Anfrage zur Verfügung.
- (3) NexAI überprüft die Wirksamkeit der Maßnahmen in angemessenen Abständen.

§ 7 Zweckbindung, kein Modelltraining

- (1) NexAI verarbeitet die personenbezogenen Daten des Kunden ausschließlich zu den in § 2 genannten Zwecken und nicht für eigene Zwecke.
- (2) NexAI verwendet die im Auftrag verarbeiteten personenbezogenen Daten **nicht zum Training, zur Weiterentwicklung, zum Fine-Tuning oder zur Verbesserung eigener oder fremder KI-Modelle.**
- (3) NexAI konfiguriert die eingesetzten Subunternehmer, soweit technisch möglich, so, dass eine Nutzung der übermittelten Daten zu Trainingszwecken ausgeschlossen ist und die Daten nicht oder nur für den kürzest möglichen, technisch vorgegebenen Zeitraum gespeichert werden (Zero-Retention- bzw. No-Training-Konfiguration). Soweit ein Subunternehmer Daten über die Erbringung der Leistung hinaus zu eigenen Zwecken verarbeitet, geschieht dies außerhalb des Auftragsverhältnisses; § 15 (Rollenmatrix) bleibt unberührt.
- (4) Eine über die Auftragserfüllung hinausgehende Verarbeitung durch NexAI zu eigenen Zwecken – insbesondere zur Produktverbesserung – erfolgt nur nach Anonymisierung oder auf gesonderter, dokumentierter Rechtsgrundlage (Art. 28 Abs. 10 DSGVO).

§ 8 Speicherorte, Speicherdauer und Löschung

- (1) Die Verarbeitung erfolgt teils intern bei NexAI, teils extern bei den in **Anhang 2 (Unterauftragsverarbeiter)** genannten Subunternehmern, ggf. auch in Drittländern nach Maßgabe von § 10.
- (2) **Grundsatz der Nichtspeicherung:** Wo eine Speicherung technisch abschaltbar ist, wird sie deaktiviert; personenbezogene Daten werden dann nur flüchtig zur Durchführung der jeweiligen Interaktion verarbeitet.
- (3) Soweit eine Speicherung technisch erforderlich ist oder auf dokumentierter Weisung des Kunden erfolgt, werden die Daten **spätestens sechs (6) Monate nach ihrer Erhebung** gelöscht, sofern nicht der Kunde eine abweichende (insbesondere kürzere) Frist weist oder eine Ausnahme nach Absatz 4 greift. Der Kunde als Verantwortlicher kann jederzeit eine frühere Löschung anweisen.
- (4) Von der Löschung ausgenommen sind Daten, deren weitere Aufbewahrung zur Erfüllung gesetzlicher Aufbewahrungspflichten oder zu Nachweiszwecken bis zum Ablauf der einschlägigen Verjährungsfristen erforderlich ist; solche Daten werden in ihrer Verarbeitung eingeschränkt (gesperrt) und nach Wegfall des Aufbewahrungsgrundes gelöscht.
- (5) **Aufzeichnung und Transkription** von Gesprächen sind standardmäßig **deaktiviert**. Sie werden nur auf ausdrückliche, dokumentierte Weisung des Kunden aktiviert und stets mit der vertraglich vorgesehenen Pflicht-Ansage (KI-Hinweis sowie ggf. Aufzeichnungshinweis) verbunden. Der Kunde verantwortet die Rechtsgrundlage einer solchen Aufzeichnung.
- (6) Führendes System für Geschäfts- und Vorgangsdaten sind die Systeme des Kunden; NexAI hält Daten insoweit nur zur Leistungserbringung vor.

§ 9 Unterauftragsverarbeiter

- (1) Der Kunde erteilt NexAI die **allgemeine schriftliche Genehmigung** zur Beauftragung von Unterauftragsverarbeitern (Art. 28 Abs. 2 Satz 2 DSGVO). Die zum Zeitpunkt des Vertragsschlusses eingesetzten Subunternehmer sind in **Anhang 2 (Unterauftragsverarbeiter)** aufgeführt und werden hiermit genehmigt.
- (2) NexAI informiert den Kunden über beabsichtigte Änderungen in Bezug auf die Hinzuziehung oder Ersetzung von Unterauftragsverarbeitern **mindestens vierzehn (14) Tage vorab in Textform** (Art. 28 Abs. 2 Satz 1 DSGVO).
- (3) Der Kunde kann einer beabsichtigten Änderung binnen der Frist aus wichtigem, datenschutzbezogenem Grund in Textform **widersprechen**. Im Fall eines berechtigten Widerspruchs bemühen sich die Parteien um eine einvernehmliche Lösung. Kann diese nicht gefunden werden und ist NexAI die Erbringung der betroffenen Leistung ohne den Subunternehmer nicht mit zumutbarem Aufwand möglich, steht jeder Partei ein **Sonderkündigungsrecht** hinsichtlich der betroffenen Leistung mit angemessener Frist zu.
- (4) NexAI verpflichtet jeden Unterauftragsverarbeiter durch Vertrag oder anderes Rechtsinstrument auf Datenschutzpflichten, die den Pflichten dieses AVV im Wesentlichen entsprechen, insbesondere auf hinreichende Garantien nach Art. 28 Abs. 3 und Abs. 4 DSGVO. Kommt der Unterauftragsverarbeiter seinen Datenschutzpflichten nicht nach, haftet NexAI gegenüber dem Kunden für die Einhaltung dieser Pflichten.
- (5) Nicht als Unterauftragsverarbeitung im Sinne dieser Regelung gelten Nebenleistungen, die NexAI als Nebenleistung in Anspruch nimmt (z. B. Telekommunikations-, Post-/Transport-, Wartungsleistungen), sofern dabei kein Zugriff auf die im Auftrag verarbeiteten Daten zum Zweck

der Verarbeitung erfolgt.

§ 10 Drittlandtransfer

- (1) Erfolgt eine Verarbeitung durch einen Unterauftragsverarbeiter in einem Drittland, stellt NexAI sicher, dass die Anforderungen der Art. 44 ff. DSGVO eingehalten werden.
- (2) Vorrangig stützt sich der Transfer auf einen **Angemessenheitsbeschluss** der Europäischen Kommission, insbesondere das EU-U.S. Data Privacy Framework (DPF), sofern der jeweilige Empfänger zertifiziert ist.
- (3) Hilfsweise – insbesondere wenn keine DPF-Zertifizierung vorliegt (bei den in Anhang 2 gekennzeichneten Empfängern, etwa Vapi, Soniox und OpenAI (USA), vorsorglich der SCC-Weg) – werden die **EU-Standardvertragsklauseln** (Durchführungsbeschluss (EU) 2021/914), **Modul 3 (Auftragsverarbeiter an Unterauftragsverarbeiter)**, abgeschlossen, ergänzt um erforderliche **Zusatzmaßnahmen** und eine **Transfer-Folgenabschätzung (Transfer Impact Assessment, TIA)**.
- (4) NexAI stellt dem Kunden auf Anfrage Nachweise über die getroffenen Transfergarantien in geeigneter Form zur Verfügung.

§ 11 Unterstützungspflichten

11.1 Betroffenenrechte

- (1) NexAI unterstützt den Kunden mit geeigneten technischen und organisatorischen Maßnahmen, soweit möglich, bei der Erfüllung von Anträgen betroffener Personen auf Wahrnehmung ihrer Rechte nach Art. 12–23 DSGVO (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch).
- (2) Wendet sich eine betroffene Person unmittelbar an NexAI, leitet NexAI das Anliegen unverzüglich an den Kunden weiter und beantwortet es nicht selbständig, es sei denn, der Kunde weist dies an.

11.2 Meldung von Datenschutzverletzungen

- (1) NexAI meldet dem Kunden jede Verletzung des Schutzes personenbezogener Daten **unverzüglich, spätestens jedoch innerhalb von vierundzwanzig (24) Stunden nach Kenntniserlangung**, in Textform (Art. 33 Abs. 2 DSGVO).
- (2) Die Meldung enthält, soweit verfügbar, eine Beschreibung der Art der Verletzung, die Kategorien und die ungefähre Zahl der betroffenen Personen und Datensätze, die wahrscheinlichen Folgen sowie die ergriffenen oder vorgeschlagenen Abhilfemaßnahmen. Soweit die Informationen nicht zeitgleich bereitgestellt werden können, dürfen sie ohne unangemessene weitere Verzögerung schrittweise nachgereicht werden.
- (3) NexAI unterstützt den Kunden bei dessen Melde- und Benachrichtigungspflichten nach Art. 33 und Art. 34 DSGVO und ergreift angemessene Maßnahmen zur Eindämmung und Behebung.

11.3 Datenschutz-Folgenabschätzung

- (1) NexAI unterstützt den Kunden unter Berücksichtigung der Art der Verarbeitung und der verfügbaren Informationen bei einer Datenschutz-Folgenabschätzung (Art. 35 DSGVO) sowie bei einer vorherigen Konsultation der Aufsichtsbehörde (Art. 36 DSGVO).

11.4 Vergütung von Unterstützungsleistungen

Unterstützungsleistungen nach diesem § 11, die über den vertraglich geschuldeten Umfang hinausgehen und nicht auf einem NexAI zuzurechnenden Umstand beruhen, kann NexAI nach vorheriger Ankündigung zu den vereinbarten bzw., soweit nicht vereinbart, den üblichen Sätzen abrechnen. Die gesetzlich geschuldeten Grundunterstützungspflichten nach Art. 28 Abs. 3 DSGVO bleiben unentgeltlich.

§ 12 Löschung und Rückgabe nach Beendigung

- (1) Nach Abschluss der Erbringung der Verarbeitungsleistungen löscht NexAI nach Wahl des Kunden alle personenbezogenen Daten oder gibt sie zurück und löscht vorhandene Kopien, sofern nicht nach Unionsrecht oder mitgliedstaatlichem Recht eine Verpflichtung zur Speicherung besteht (Art. 28 Abs. 3 lit. g DSGVO).
- (2) NexAI stellt dem Kunden vor der Löschung für einen Zeitraum von **dreiig (30) Tagen** die Möglichkeit zum **Export** der Daten in einem gängigen, strukturierten Format bereit. Nach Ablauf dieser Frist bzw. nach erfolgtem Export werden die Daten gelöscht.
- (3) NexAI bestätigt die Löschung auf Verlangen in **Textform** (Löschbestätigung).
- (4) Unterliegen Daten gesetzlichen Aufbewahrungspflichten (insbesondere § 147 AO, § 257 HGB), werden diese nicht gelöscht, sondern in ihrer Verarbeitung **eingeschränkt (gesperrt)** (Art. 18 DSGVO) und nach Ablauf der Aufbewahrungsfrist gelöscht.

§ 13 Nachweis- und Kontrollrechte (Audit)

- (1) NexAI stellt dem Kunden alle erforderlichen Informationen zum Nachweis der Einhaltung der Pflichten aus Art. 28 DSGVO zur Verfügung und ermöglicht Überprüfungen – einschließlich Inspektionen –, die vom Kunden oder einem von diesem beauftragten Prüfer durchgeführt werden, und trägt zu diesen bei (Art. 28 Abs. 3 lit. h DSGVO).
- (2) Der Nachweis kann durch geeignete Dokumentation, aktuelle Testate, Zertifizierungen oder Berichte unabhängiger Stellen erbracht werden. Reichen diese zur Ausräumung eines konkreten Prüfbedarfs nicht aus, kann der Kunde nach rechtzeitiger Vorankündigung (in der Regel mindestens vierzehn (14) Tage vorab) und zu üblichen Geschäftszeiten eine Vor-Ort-Prüfung durchführen, ohne den Betriebsablauf unverhältnismäßig zu beeinträchtigen und unter Wahrung der Vertraulichkeit sowie der Rechte Dritter.
- (3) Der beauftragte Prüfer darf nicht in einem Wettbewerbsverhältnis zu NexAI stehen und ist zur Vertraulichkeit zu verpflichten.
- (4) Prüfungen, die über eine (1) reguläre Prüfung pro Jahr hinausgehen oder auf Verlangen des Kunden ohne konkreten Anlass erfolgen, kann NexAI den hierdurch entstehenden angemessenen Aufwand zu den üblichen Sätzen in Rechnung stellen. Prüfungen aus konkretem Anlass sowie die gesetzlich geschuldete Bereitstellung von Nachweisen bleiben hiervon unberührt.

§ 14 Datenschutzbeauftragter, Verzeichnis, Kontaktstelle

- (1) NexAI benennt einen Datenschutzbeauftragten, sofern und soweit eine gesetzliche Benennungspflicht besteht. Kontaktstelle für Datenschutzangelegenheiten und für Weisungen nach § 4 Abs. 2 ist mbt@nex-a-i.com.
- (2) NexAI führt ein Verzeichnis aller Kategorien von im Auftrag durchgeführten Verarbeitungstätigkeiten (Art. 30 Abs. 2 DSGVO).

Datenschutzkontakt des Kunden (Name, E-Mail):

§ 15 Rollenmatrix nach Leistungsart

Die datenschutzrechtliche Rolle von NexAI richtet sich nach der jeweils beauftragten Leistung. Die im Auftragsformular je Leistung getroffene Zuordnung ist maßgeblich; im Zweifel gilt die nachstehende Matrix:

Leistung / Agent	Rolle NexAI	Rechtsrahmen
Voice Agent (eingehend)	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
Voice Agent (ausgehend, vom Kunden veranlasste Ansprache)	Auftragsverarbeiter; die Zulässigkeit der Ansprache verantwortet der Kunde	Art. 28 DSGVO / dieser AVV; § 15 des Rahmenvertrages
Chat Agent	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
Automatisierungen	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
Individuelle KI-Agenten	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
NexAI CRM	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
NexAI Kalender	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
NexAI App / individuelle Anwendungen	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV

- (1) NexAI verarbeitet die in den Anwendungen gespeicherten Daten ausschließlich weisungsgebunden für den Kunden und nicht für eigene Zwecke. Eine Recherche oder Beschaffung von Kontaktdaten durch NexAI ist nicht Gegenstand der Leistungen (Anlage A, Ziffer 14).
- (2) Setzt der Kunde einen Agenten für ausgehende Ansprache oder Direktwerbung ein, bleibt NexAI Auftragsverarbeiter; die Rechtmäßigkeit der Ansprache und die Erfüllung der Informationspflichten nach Art. 13 und 14 DSGVO verantwortet der Kunde (§ 15 des Rahmenvertrages).
- (3) Die Klarstellung in § 1 Abs. 5 (eigene Verantwortlichkeit von NexAI) bleibt unberührt.

§ 16 Haftung und Innenausgleich

- (1) Für die Haftung im Außenverhältnis gegenüber betroffenen Personen gilt Art. 82 DSGVO. Im Innenverhältnis tragen die Parteien einen etwaigen Schaden bzw. eine Geldbuße nach dem **Maß ihres jeweiligen Verantwortungsanteils** an dem zugrunde liegenden Verstoß (Art. 82 Abs. 5 DSGVO).
- (2) Hat eine Partei an eine betroffene Person Schadensersatz geleistet, der über ihren Verantwortungsanteil hinausgeht, kann sie von der anderen Partei den auf deren Anteil entfallenden Teil zurückfordern.
- (3) Die übrigen Haftungsregelungen des Rahmenvertrags (dort § Haftung/Haftungsbeschränkung) gelten für das Verhältnis der Parteien untereinander ergänzend, soweit sie zwingendem Datenschutzrecht nicht entgegenstehen.

§ 17 Schlussbestimmungen

- (1) Änderungen und Ergänzungen dieses AVV bedürfen der Textform. Dies gilt auch für die Aufhebung dieses Textformerfordernisses. Vorrangige Individualabreden (§ 305b BGB) bleiben unberührt.
- (2) Sollte eine Bestimmung dieses AVV unwirksam sein oder werden, bleibt die Wirksamkeit der übrigen Bestimmungen unberührt.
- (3) Es gilt das Recht der Bundesrepublik Deutschland unter Ausschluss des UN-Kaufrechts. Ausschließlicher Gerichtsstand für alle Streitigkeiten aus oder im Zusammenhang mit diesem AVV ist – soweit gesetzlich zulässig – der Sitz von NexAI.
- (4) Die Anhänge 1 (TOM) und 2 (Unterauftragsverarbeiter) sind Bestandteil dieses AVV.

Anhang 1 Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

1. Mandantentrennung / Trennungskontrolle

- getrennte Projekte, Workspaces und API-Keys je Kunde bei den eingesetzten Diensten;
- logische Trennung der Datenbestände; keine kundenübergreifende Zusammenführung;
- getrennte Verarbeitung von Test-/Entwicklungs- und Produktivdaten.

2. Zugangs- und Zugriffskontrolle

- Multi-Faktor-Authentifizierung (MFA) für administrative Zugänge;
- Least-Privilege-Prinzip: rollenbasierte, auf das Erforderliche beschränkte Berechtigungen;
- kein Produktivbetrieb über rein private Endnutzer-Accounts; Nutzung dedizierter Betriebs-Accounts;
- Passwort-Richtlinien und sichere Verwahrung von Geheimnissen/Schlüsseln;
- regelmäßige Überprüfung und Entzug nicht mehr benötigter Berechtigungen.

3. Verschlüsselung / Weitergabekontrolle

- Transportverschlüsselung (TLS) bei der Übertragung personenbezogener Daten;
- Verschlüsselung ruhender Daten, soweit von den eingesetzten Diensten unterstützt;
- gesicherte Schnittstellen (authentifizierte APIs/Webhooks).

4. Eingabe- und Protokollierungskontrolle

- Zugriffs- und Aktivitätsprotokollierung in den administrativen Systemen;
- Nachvollziehbarkeit wesentlicher Konfigurations- und Verarbeitungsvorgänge.

5. Verfügbarkeit und Belastbarkeit

- Nutzung etablierter, ausfallsicherer Cloud-Infrastruktur der Subunternehmer;
- Maßnahmen zur Wiederherstellbarkeit im Rahmen der Möglichkeiten der genutzten Dienste.

6. Datenminimierung und Löschung

- Deaktivierung der Speicherung, wo technisch möglich (Grundsatz der Nichtspeicherung);
- standardmäßig deaktivierte Aufzeichnung/Transkription;
- automatisierte Löschroutinen (Löschung spätestens sechs Monate nach Erhebung, soweit keine Ausnahme greift);
- Zero-Retention-/No-Training-Konfiguration der Subunternehmer, soweit technisch verfügbar.

7. Auftragskontrolle und Organisation

- Verpflichtung der beteiligten Personen auf Vertraulichkeit;
- vertragliche Bindung der Unterauftragsverarbeiter auf entsprechende Schutzpflichten;
- dokumentierte Weisungslage; Verzeichnis der Verarbeitungstätigkeiten (Art. 30 Abs. 2 DSGVO).

Anhang 2 Unterauftragsverarbeiter

Die folgenden Unterauftragsverarbeiter sind zum Zeitpunkt des Vertragsschlusses eingesetzt und werden vom Kunden allgemein genehmigt (§ 9). Der konkrete Einsatz richtet sich nach den beauftragten Agenten und Anwendungen. Nicht bei jedem Kunden kommen sämtliche Dienste zum Einsatz.

Name	Sitz / Land	Leistung	Datenkategorien	Transfermechanismus
Vapi Inc.	USA	Voice-Agent-Plattform (Sprachdialog, Telefonie-Orchestrierung, Sprachsynthese)	Gesprächsinhalte, Metadaten, Rufnummern	EU-SCC Modul 3 + Zusatzmaßnahmen + TIA (kein DPF)
Soniox Inc	USA	Spracherkennung (Speech-to-Text); als Unterauftragsverarbeiter von Vapi eingesetzt	Audio-/Sprachdateien, daraus erzeugte Transkripte, Metadaten	EU-SCC Modul 3 + Zusatzmaßnahmen + TIA (über Vapi-DPA)
OpenAI Ireland Ltd. / OpenAI, L.L.C.	EU / USA	Sprachmodell / KI-Verarbeitung (Textverstehen, Antwortgenerierung)	Gesprächs-/Textinhalte, Metadaten	EU-SCC Modul 3 + Zusatzmaßnahmen + TIA (kein DPF); No-Training-Konfiguration
Anthropic PBC	USA	Sprachmodell / KI-Verarbeitung (Einstufung eingehender Nachrichten, Antwortentwürfe, Übersetzung, Zusammenfassung verlinkter Seiten); eingesetzt im NexAI Mail Agent	Inhalte eingehender und gesendeter Nachrichten samt Anhängen, Metadaten	EU-SCC Modul 3 + Zusatzmaßnahmen + TIA (kein DPF); No-Training-Konfiguration
Google LLC / Google Ireland Ltd.	EU / USA	Kalender-, Sheets-, Gmail-/Workspace-Dienste (Terminverwaltung, Bestätigungen, Lead-Ablage)	Termin-, Kontakt-, Vorgangsdaten, Metadaten	DPF, hilfsweise EU-SCC Modul 3
easybell GmbH	Deutschland	Telefonie-Anbindung (SIP-Trunk)	Rufnummern, Verbindungs-/Metadaten	EU-intern; kein Drittlandtransfer

Name	Sitz / Land	Leistung	Datenkategorien	Transfermechanismus
Hetzner Online GmbH	Deutschland	Hosting und Betrieb der von NexAI selbst betriebenen Systeme (Automatisierungen/n8n, NexAI CRM, NexAI Kalender, NexAI App)	je nach Leistung: Kontakt-, Vorgangs-, Termin-, Aufgaben-, Beleg- und Protokolldaten	EU-intern; kein Drittlandtransfer
seven communications GmbH & Co. KG	Köln, Deutschland	Versand von SMS (Terminbestätigungen und Erinnerungen); nur bei beauftragtem SMS-Versand	Rufnummer der Empfängerin bzw. des Empfängers, Inhalt der Nachricht	EU-intern; kein Drittlandtransfer
Resend, Inc.	USA (Verarbeitung in der EU-Region Irland)	Versand von System-E-Mails (Bestätigungen, Erinnerungen, Benachrichtigungen aus den Anwendungen)	E-Mail-Adresse, Name, Inhalt der Nachricht	DPF-zertifiziert; ergänzend EU-SCC Modul 3

Ergänzende / abweichende Subunternehmer (kundenspezifisch):

Sitzangaben und Transfermechanismen können sich ändern; maßgeblich ist die jeweils aktuelle, dem Kunden nach § 9 Abs. 2 mitgeteilte Fassung. Bei Diensten mit EU-Niederlassung wird die Verarbeitung vorrangig über die EU-Entität abgewickelt.

Unterschriften

Die Parteien schließen diesen Vertrag zur Auftragsverarbeitung einschließlich seiner Anhänge 1 und 2 verbindlich ab.

Für NexAI

Für NexAI

Für den Kunden

Ort, Datum
Maximilian Trenk (Gesellschafter)

Ort, Datum
Jason Brian Merklein
(Gesellschafter)

Ort, Datum
Name / Funktion

Dieser AVV ist ein sorgfältig erstellter Entwurf. Er ersetzt keine Rechtsberatung und sollte vor Verwendung im Einzelfall anwaltlich geprüft und an die konkrete Verarbeitungssituation angepasst werden.